

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
December 2025	Planning 5	Reference Material Data Privacy and Protection	Dana Wendlova	Update and new relevant links Replaced reference to GPA with PIA, removed invalid links to Privacy Audit Programs – for actual program instructions, please refer to the general Audit Program Box folder and the Audit Programs for Privacy.
December 2024	2,3,4	Control Assessment Questions	Shawn Kronenberger	Annual review process updates
November 2023	All	All	Jen Daniels	Updated defined risk areas and tests to align with most recent audit. Added data privacy and protection.
May 2023	All	All	Jen Daniels	Audit program name change from Royalty Payment Management to Royalty and Payment Management; changed defined risk areas; reference links
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

Table of Contents	
PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	6
PLANNING: Fraud Template	7
CONTROL ASSESSMENT QUESTIONS.....	8
Key Control Question: 1. Third-Party Supplier Agreements	8
Primary Test: Agreement Management (PC001.P).....	9
Key Control Question: 2. Third-Party Supplier Agreement Payments and Payment Controls	10
Primary Test: Third-Party Supplier Agreement Payments (SR001.P)	11
Primary Test: Processing Controls (SR002.P)	12
Key Control Question: 3. Financial and Reporting Accuracy.....	13
Primary Test: Measurements and Exception Handling (FA001.P)	14
Key Control Question: 4. Agreement Owner (AO)	15
Primary Test: Agreement Owner (AO) (PF001.P).....	16
Key Control Question: 5. Data Privacy	19
Primary Test: Data Privacy and Protection (OT002.P)	20

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

PROCESS AND OBJECTIVE

Royalty & Payment Management (R&PM) is the process to provide for timely and accurate financial administration of third-party supplier agreements which allow IBM to generate revenue, based on distribution or use of same supplier's asset. The centralized R&PM department review includes draft agreements, calculating third-party supplier agreement payments, interfacing with Accounts Payable for supplier payments, and the general ledger for financial reporting. The integrity and accuracy of the payments facilitated by the centralized R&PM department is dependent upon the work performed by each Business Unit (BU) Agreement Owner (AO) responsible for third-party supplier agreements. Each BU AO review includes local process documentation, desk-level procedures, training materials, separation of duties assessment, approval matrix and delegations of authority, copies of third-party supplier agreements, payment reconciliations, calculations of adjustments, calculations supporting contractual minimums, communications logs, and problem escalation procedures.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

PLANNING: Audit Program Risk Alignment

Royalty and Payment Management

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Agreement Pre-Approval Management	High	Third-Party Supplier Agreements	PC001.P
Data Privacy	High	Data Privacy	DP001.P
Royalty and Payment Management	Medium	Third-Party Supplier Agreement Payments and Payment Controls	SR001.P
Lifecycle Management	Low	Agreement Owner (AO)	PF001.P
IT Verification and Validation	Low	Third-Party Supplier Agreement Payments and Payment Controls	SR002.P
Royalty and Payment Management System Setup	Low	Agreement Owner (AO)	PF001.P
Agreement Validation	Low	Third-Party Supplier Agreement Payments and Payment Controls	SR002.P
Measurements	Low	Financial and Reporting Accuracy	FA001.P

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
• Universe of software contracts • Payment universe	• contracts with non-standard T&C • types of contracts (fixed / var) • contracts with high-dollar amounts • new contracts with adjustments and advances	• payments made after contract expired • payment made before contract inception	• Not adhering to the T&Cs of the contract could result in inaccurate payments, customer dissatisfaction, and penalties for late payments. • Royalty payments disbursed prior to the execution of a signed contract with appropriate approvals could lead to unauth. payments. • Failure to obtain all required contract approvals could result in unauthorized commitments. • Inaccurate & untimely royalty payments could result in over-payment & customer dissatisfaction. • Inadequate risk analysis by product line management (PLM) on the use of fixed fee or advance royalty contracts could result in reduced profit margin.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

PLANNING: Reference Material

Royalty & Payment Management (R&PM) Agreement Owner (AO) Education:
<https://w3.ibm.com/w3publisher/royaltyhubonboarding>

Accounting Practices

AP53: Software Revenue Recognition - This accounting practice establishes requirements for the timing of revenue recognition for licensing, selling, leasing, or otherwise marketing computer software

Global Vendor Accounts Payable Manual (GVAPM)

Worldwide Accounting website: <https://w3.ibm.com/w3publisher/ibmaccounting>

Integrated Supply Chain (ISC) Links

IBM Global Procurement web site: <https://w3.ibm.com/w3publisher/procurement-ibm>

Accounting Practices and Instructions
<https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting/accounting-practices-interpretations>

CI FIN 182 Appendix C - Separation of Duties (SOD) - <https://w3.ibm.com/w3publisher/financebc/ibm-framework/ci-fin-182-appendix-c>

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Commitment to vendors without proper approval	Procurement	Test that payments are authorized and not made prior to contract start date
Excessive access or conflicting roles and responsibilities	SOD	Test for annual SOD
Improper cost reporting to meet financial targets	Financial reviews	Sample large and unusual transactions especially around quarter and year end

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Third-Party Supplier Agreements

Objective:

To determine if third-party supplier agreements include the model contract language which helps maximize the financial return from a third-party relationship while minimizing the risk and optimizes the ability to administer the contract.

Risk/Exposure:

Agreement terms and conditions, including a clear definition of the scope of work, must be clearly stated in the contract, or prolonged disputes with vendors can result which could impact the continuity of services.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Third-Party Supplier Agreements

Primary Test: Agreement Management (PC001.P)

Objective:

To confirm that third-party supplier agreements include the model contract language which helps maximize the financial return from a third-party relationship while minimizing the risk and optimizes the ability to administer the contract.

Approach:

Review the third-party supplier agreements process. Obtain a list of agreements initiated and in-force during the audit scope period and test the following attributes.

1. Determine if third-party supplier agreements were consistent with the requirements of the process.
2. Are the agreements signed? Was an Agreement Owner (AO) certification form completed and was the input sheet submitted by the AO?
3. Were any nonstandard contract terms and conditions documented?
4. Were any nonstandard contract terms and conditions reviewed, and were all required approvals obtained?
5. If non-standard terms and conditions required additional steps performed by AO, was a risk assessment performed and document of understanding/Exception Management Process (EMP) signed?
6. Were the agreements and any associated documents of understanding reviewed annually? Was the contract information reviewed upon changes in the contract?
7. Ascertain whether sufficient audit trails exist including retention records showing processing transaction history.
8. Was the applicable tax treatment (withholding taxes and/or sales taxes/value added taxes) for the invoices specified in the contract?

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Third-Party Supplier Agreement Payments and Payment Controls

Objective:

To determine that third-party supplier agreement payments were processed accurately and timely, and payment controls were adequate to determine the adequacy of controls over the receipt of electronic data.

Risk/Exposure:

Incorrect or invalid payments could occur without adequate disbursement controls. Supplier dissatisfaction and financial loss may result if disbursements are not in compliance with contract terms and conditions, valid, verified, approved, and paid in a timely manner.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Third-Party Supplier Agreement Payments and Payment Controls

Primary Test: Third-Party Supplier Agreement Payments (SR001.P)

Objective:

To validate that Third-Party Supplier Agreement Payments are accurate and approved prior to submission to the accounts payable organization.

Approach:

Select a sample of payments exceeding \$250,000.

1. Were any payments made after a contract was fully executed?
2. Were the payment amounts correct, including any withholding tax or sales tax/value added taxes treatment?
3. Validate that payment amounts were approved, and the approver was within delegated limits.
4. Determine if there were advances and if they were processed correctly.
5. Were third-party supplier agreement payments posted correctly by Royalty & Payment Management (R&PM)?
6. Was payment activity reviewed monthly with R&PM management? Was the vendor payment summary reviewed, signed, and dated by two levels of Third-Party Supplier Agreement Payments management?
7. For variable payments, validate that payment reconciliation was performed.

Note: Delays in recognizing third-party supplier agreement payments due, can result in the understatement of costs/expenses and an overstatement of revenue.

Determine whether other types of payments, such as check requests, are processed in addition to third-party supplier agreement payments. Review and test associated controls and documentation.

ROYALTY AND PAYMENT MANAGEMENT

AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Third-Party Supplier Agreement Payments and Payment Controls

Primary Test: Processing Controls (SR002.P)

Objective:

To confirm that electronic data for third-party supplier agreement payments is processed in a timely and accurate manner, and to determine the adequacy of controls over the receipt of electronic data.

Approach:

1. Review the process for receiving and processing of third-party supplier agreement payment data. Select a sample of payments and test against the following attributes. (Note: The sample can be stratified according to value or type of payment, judgmental, or random. The selection and attributes to be tested should be based on the type of processing environment.)
 - Determine the timing for receipt of electronic software royalty data. Have targets for timeliness of processing been established?
 - Do controls exist to validate the royalty payment against the third-party supplier agreement terms?
 - Determine whether data entry revalidation checks are performed.
 - Ascertain whether sufficient audit trails exist including retention of third-party supplier agreement payment information and records showing processing transaction history.

Coordinate the following two test questions with the Process Application Review (80-10-00).
2. Review application systems flows and interdependencies for the accounts payable environment and determine whether third-party supplier agreement payment data is transmitted to the accounts payable application from upstream feeder systems. Ascertain whether controls exist to verify the completeness of data transmission. Review control/monitor reports and identify transmission failures; verify that appropriate investigative and corrective actions were taken.
3. Where front-end applications are the primary method of third-party supplier agreement payment data-entry, confirm that procedures exist to identify failed transmissions (e.g., sequential numbering controls, batch transmission controls) and whether these are reconciled and resolved.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial and Reporting Accuracy

Objective:

To validate that financial controls for third-party supplier agreement payment management activity adequately assure the appropriate placement of checks and balances throughout the process. To determine if there was sufficient management involvement within the key control points and activities, that monitoring and control functions surface exception conditions, and appropriate corrective actions were implemented.

Risk/Exposure:

Ineffective financial controls could result in inaccurate royalty payment data, payments, and reporting.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial and Reporting Accuracy

Primary Test: Measurements and Exception Handling (FA001.P)

Objective:

Are measurements in place to provide management with visibility of operational efficiency? Are exception conditions identified, reported, and properly resolved?

Approach:

1. Do measurements exist to gauge operational efficiency and process exceptions? Confirm processing targets and service level commitments and ascertain whether these are being met. Suggested areas to review are:
 - Late Payments / Uncorrected Errors
 - Payment Processing Accuracy
 - Carry Forward Balance Analysis
 - General Ledger Batch Miscodes
 - Peer Review
 - Advance Summary Report
 - Adjustment Trend Analysis
2. Where performance levels are below target, investigate reasons why and determine whether action plans have been implemented to correct defective performance.
3. In collaboration with IBM accounting, review monthly reconciliations for R&PM payment analysis, R&PM cost analysis.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Agreement Owner (AO)

Objective:

The integrity and accuracy of the payments facilitated by the centralized R&PM department is dependent upon the work performed by each Business Unit (BU) Agreement Owner (AO) responsible for administering software royalty contracts for a specific product(s), brand(s), or lab site.

Risk/Exposure:

The lack of a well-defined AO role could affect the integrity and accuracy of payments facilitated by the centralized R&PM department.

NOTE: All AOs are either business development or development within the business unit; often offering managers. There are no contracting AOs that do the admin role.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Agreement Owner (AO)

Primary Test: Agreement Owner (AO) (PF001.P)

Objective:

Each Business Unit Agreement Owner review should include local process documentation, desk-level procedures, training materials, separation of duties assessment, approval matrix and delegations of authority, copies of third-party supplier agreements, royalty and payment reconciliations, calculations of adjustments, calculations supporting contractual minimums (for those minimums not calculated by R&PM) communications logs, and problem escalation procedures.

Approach:

Review the following documentation to determine if the controls executed by the Agreement Owner are adequate to protect IBM.

Process Documentation and Desk-Level Procedures

1. Review process documentation and flowcharts to specifically understand business control points, documentation requirements, validation steps, administration of negative confirmations, reconciliations, approvals, separation of duties, records retention requirements, etc.
2. Confirm that all Agreement Owner have documented desk-level procedures. Is training provided for new AOs to facilitate consistency in the performance of their roles and responsibilities?

Memorandum of Understanding (MOU) and Contractual Documentation

1. Confirm that each Agreement Owner as contract managers had executed an AO Certification Form and the Business Unit had received a Memorandum of Understanding (MOU) from the R&PM organization.
2. Verify that there is an ongoing process to ensure AO Certification Forms or Exception Management Process (EMP)s are updated as staff members and job responsibilities change. At a minimum, this verification must be done annually.
3. Validate that each Agreement Owner retains a copy of all active third-party supplier agreements for which he or she maintains responsibility. Other signed and fully executed agreements should be maintained in accordance with IBM records management guidelines.
4. Confirm that each organization (Business Unit, Lab, etc.) uses the IBM Global Procurement model agreement templates for all new royalty relationships, if applicable.

NOTE: All AOs are either business development or development within the business unit; often offering managers. There are no contracting AOs that do the admin role.

Receipt of Goods and Services, Process Timeliness, and Staffing Considerations

1. Verify that there is an Agreement Owner process for validating that the payment amounts are correct.
2. Using the third-party supplier agreement, does the AO have a process to verify that the rate and calculations are accurate and are in accordance with the terms of the third-party supplier agreement. Can the results of this verification be demonstrated?

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Agreement Owner (AO)

Primary Test: Agreement Owner (AO) (PF001.P)

(Continued)

Note: There are three internal software usage indicators associated with the FIW. An indicator of "1" is a productive internal use, "2" is a nonproductive internal use, and if neither one of these indicators is used and the fulfillment process does not distinguish between productive and nonproductive internals, then the default indicator "I" is used. A "I" indicator is treated as a productive internal use for payment calculations. Thus, payments which include internal activity may be overstated due to nonproductive activity being treated as productive.

3. Were all contract obligations added to the system and tracked/managed timely?
4. Is there an automated control to prevent restricted products from being processed to the internal download website?
5. Is the quarterly review process for internal customer transactions to analyze potential overpayments performed?
6. What is the Agreement Owner process for ensuring that all third-party supplier statements supplied by R&PM have been reviewed and documented prior to the deadline assigned by the R&PM organization?
7. Are all exceptions documented, fully explained, and approved by management?
8. Does each Agreement Owner have an assigned back-up to ensure that all payment negative confirmations are reviewed in a timely manner during the absence of the principal employee?

Payment Advances

1. Does Agreement Owner have a process for issuance of all payment advances?
2. Are all advances supported by business justification and management approval?
3. Does the Agreement Owner analyze the quarterly advance report and obtain management authorization on all actions taken to recover advances?
4. Does the Agreement Owner have a procedure to administer and communicate unrecoverable advances?

Separation of Duties and Management Authorizations

1. Can the Agreement Owner demonstrate proper separation of duties (SOD) within their process?
2. If a SOD exposure exists for any role, is there a formal risk acceptance executed? Do appropriate secondary controls exist, and can they be demonstrated?
3. Can each Agreement Owner demonstrate that they are in compliance with IBM delegation of authority requirements?

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Agreement Owner (AO)

Primary Test: Agreement Owner (AO) (PF001.P)

(Continued)

Communications

1. What is the Agreement Owner process for communicating errors and discrepancies that are identified during the validation of each payment (during the negative confirmation timeframe) and prior to the R&PM deadline for payments?
2. Does each Agreement Owner maintain a communications log for R&PM related complaints?
3. Is there a documented escalation path for problem resolution within the local R&PM process?
4. Does each Agreement Owner have a formal process for being notified of new products through the Request for Announcement (RFA) process? New products could result in a requirement to pay additional fees.
5. Does each Agreement Owner have a formal process for being notified of the elimination of old products (Withdrawal from Marketing)? Eliminated products, if not eliminated in a timely manner, could result in erroneous payments.
6. Did the Agreement Owners (AO) annually validate parts, rates and other agreement setup data directly in Royalty Hub?

Reporting and Validation Requirements

1. Are management reviews, self-audits, or other outside reviews of the payment reconciliations performed and documented? Is the frequency of the reviews sufficient to detect potential concerns? Are any resulting required actions to be taken as a result of the review documented?

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Data Privacy

Objective:

This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process.

Risk/Exposure:

Failure to protect PI and SPI could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation.

ROYALTY AND PAYMENT MANAGEMENT AUDIT PROGRAM #18-35-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Data Privacy

Primary Test: Data Privacy and Protection (OT002.P)

Objective:

This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect personal information (PI) and sensitive personal information (SPI).

Risk or Exposure:

Failure to comply with applicable laws and regulations may include fines or penalties.

Test: Privacy

Privacy laws impose requirements on how IBM and its clients process Personal Information (PI). The Privacy Impact Assessment (PIA) Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis. This is NA. R&PM is not processor. It is IBM dev / offering team that handles this part of process. In IDR we marked this question as N/A.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of PIA for the processes and/or assets.

For complete and updated testing instructions please refer to the Audit Program for Privacy.

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities.

For complete and updated testing instructions please refer to the Audit Program for Privacy.

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk. N/A